

2026 Incognito Team Project Report

팀명: Antifragile 팀장: 정지민 팀원: 김은비, 양태석, 이재우

1. 프로젝트 개요

1.1. 서론

클라우드 컴퓨팅 환경의 확산과 함께 기업 인프라의 운영 방식은 빠르게 변화하고 있으며, 이에 따라 사이버 공격의 형태 또한 점점 더 지능화 및 자동화되고 있다. 특히 Amazon Web Services와 같은 퍼블릭 클라우드 환경에서는 인프라가 동적으로 생성 및 확장되는 특성으로 인해 공격 표면(Attack Surface)이 넓어지고, 다음과 같은 공격 유형이 빈번하게 발생하고 있다. [1]

❶ S3 bucket 하이재킹

- 외부 리소스(S3)에 대한 신뢰 악용
- 공급망 공격 (Supply Chain Attack)
- 악성 바이너리 삽입 -> 사용자 환경 침투

❷ 자격 증명 악용

- IAM / API 권한 문제 및 자격 증명 탈취
- 권한 상승 -> 내부 확산 -> 데이터 탈취

이러한 공격은 최종적으로 악성 코드 실행, C2(Command & Control) 통신, 내부 자원 악용과 같은 후속 행위로 이어지는 공통적인 패턴을 보인다.

현재 클라우드 보안 환경에서는 Amazon GuardDuty, AWS Security Hub 등 다양한 보안 서비스가 제공되어 위협 탐지 및 이벤트 통합 기능을 지원하고 있으며, 일부 자동 대응 기능 또한 제공되고 있다. 그러나 실제 운영 환경에서는 오탐(False Positive) 및 서비스 중단 위험으로 인해 자동 대응이 제한적으로 활용되며, 사람의 판단이 개입되는 반자동 대응 구조가 일반적이다.

이로 인해 탐지 이후 대응까지의 과정에서 지연이 발생하거나, 이벤트 간 연관성을 충분히 고려하지 못한 단편적인 대응이 이루어지는 문제가 존재한다.

1.2. 프로젝트 목적

이와 같은 배경을 바탕으로, 본 프로젝트는 다양한 공격 경로에서 발생하는 보안 위협을 개별적으로 처리하는 기존 방식에서 벗어나, 공격의 결과 단계에서 공통적으로 나타나는 이상 행위를 중심으로 대응할 수 있는 통합 보안 대응 체계를 구축하는 것을 목적으로 한다.

공급망 공격이나 자격 증명 탈취와 같이 다양한 형태의 공격이 존재하더라도, 최종적으로는 C2 통신, 악성 코드 실행, 내부 자원 악용과 같은 후속 행위로 수렴한다는 점에 주목하였다. 이에 따라 본 프로젝트에서는 이러한 공통적인 이상 행위를 기반으로 위협을 탐지하고 대응하는 구조를 설계하였다. 또한, 기존 클라우드 보안 환경에서 주로 사용되는 반자동 대응 구조의 한계를 극복하기 위해 보안 이벤트 발생 시 자동 대응이 이루어지되 slack를 통한 알림 및 관리자의 개입이 가능하도록 하는 자율 보안 대응(Self-Healing Security) 구조를 구현하고자 한다. 이를 위해 탐지된 이벤트를 단순히 수집하는 행위를 넘어 AI 기반 분석을 통해 위협의 위험도를 판단하고 대응 전략을 결정한 뒤, 이를 자동으로 실행하는 체계를 구축하였다.

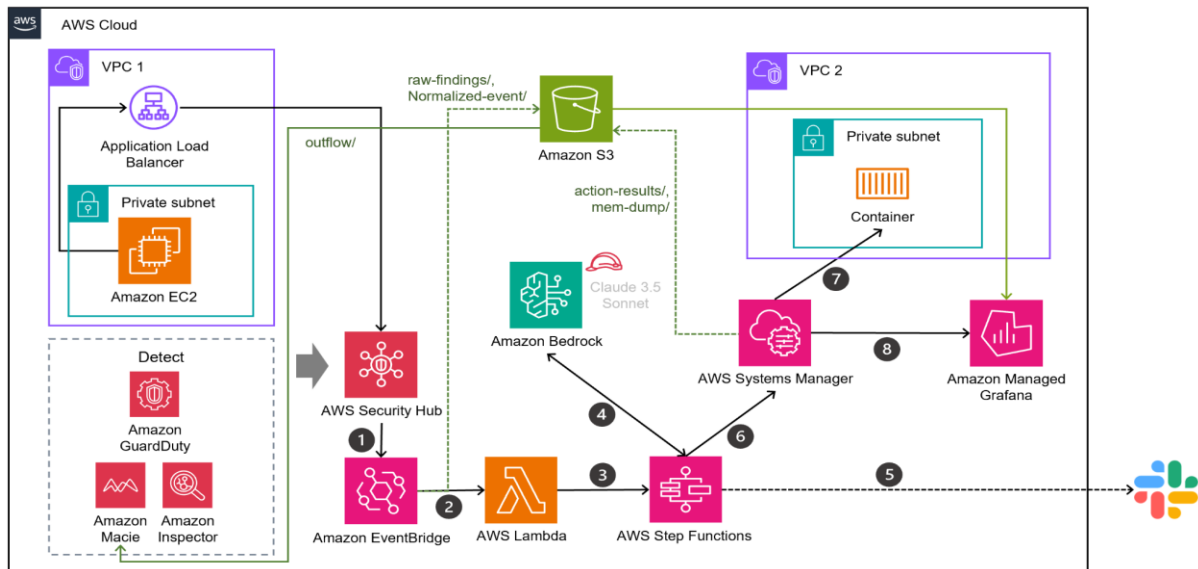
구현은 Amazon Web Services 환경에서 Terraform 기반 인프라 구성과 이벤트 기반(Event-Driven) 파이프라인을 결합하여, 탐지 -> 분석 -> 대응 -> 알림 -> 모니터링까지의 전 과정을 하나의 흐름으로 연결된 자동화 시스템으로 설계하였다.

개념적으로는, CIS Controls에서의 Respond 분류에 해당하는 대부분의 Safeguards를 따르고, Recover에 해당하는 일부 Safeguards를 만족해 유연성과 편의성을 동시에 가지는 시스템을 구성하였다.

결론적으로, AI 기반 의사결정과 자동 실행이 결합된 End-to-End 보안 대응 체계를 구축하고, 실제 공격 시나리오 기반 테스트를 통해 그 실효성을 검증하는 것을 목표로 한다.

2. 아키텍처 구조

[프로젝트 아키텍처 구조도]



2.1. 이벤트 기반 보안 대응 흐름

본 시스템은 클라우드 환경에서 발생하는 보안 이벤트를 자동으로 처리하기 위해 이벤트 기반(Event-Driven) 아키텍처로 설계되었다. 전체 흐름은 다음과 같다.

탐지 -> 이벤트 수집 -> 정규화 -> AI 분석 -> 대응 결정 -> 자동 대응 실행 -> 로그 저장 및 모니터링

이러한 과정은 모두 terraform에서의 자동화된 파이프라인으로 연결되어 있으며, 각 단계는 AWS 관리형 서비스를 기반으로 구성된다.

2.2. 보안 이벤트 수집 및 필터링

보안 이벤트는 AWS Security Hub를 통해 통합되며, 이후 Amazon EventBridge를 통해 Lambda로 전달된다.

Lambda 함수는 전달된 이벤트에서 다음의 정보를 추출한다.

- finding_id
- product_name(GuardDuty or Macie or Inspector)
- severity
- finding_type
- instance_id

이후 EC2 리소스가 포함된 이벤트만 자동 대응 대상으로 필터링하며, 허용된 보안 서비스 및 finding type에 대해서만 처리한다.

특히 finding type은 prefix 기반으로 필터링되며, 다음과 같은 유형을 허용한다.

- Backdoor:EC2
- Trojan:EC2
- CryptoCurrency:EC2
- SensitiveData:S3 등

이를 통해 다양한 공격 시나리오에 대해 유연하게 대응할 수 있도록 설계하였다.

2.3. 이벤트 정규화 및 로그 저장

필터링된 이벤트는 대응에 필요한 최소 정보만 포함하도록 정규화되며, 이후 S3에 저장된다. ㄹ

- ① raw-findings/: 원본 이벤트 저장
- ② normalized-event/: 정규화된 이벤트 저장

이 데이터는 이후 분석 및 감사, 시나리오 테스트, 모니터링을 위한 기반으로 활용된다.

2.4. Step Functions 기반 대응 오케스트레이션

정규화된 이벤트는 AWS Step Functions로 전달되어 전체 대응 흐름을 제어한다.

각 이벤트는 고유한 execution name을 기반으로 실행되며, 중복 실행을 방지하기 위해 UUID 기반 식별자를 포함한다.

특히 본 시스템은 조건 분기 및 병렬 처리를 포함한 워크플로우로 구성되어 있다. 먼저 이벤트의 severity를 기준으로 대응 전략이 분기된다.

- ① HIGH / CRITICAL -> AI 분석 수행
- ② other -> 기본 처리 또는 종료

이를 통해 불필요한 AI 호출을 줄이고 고위험 이벤트에 집중할 수 있도록 한다.

2.5. AI 기반 분석

본 시스템의 핵심 중 하나로, Amazon Bedrock을 활용한 분석 구조가 존재한다.

(1) Analyze 단계 (1차 분석)

최소 이벤트 발생 시, AI는 다음을 수행한다.

- 이벤트 요약
- 위험도 평가
- 영향도 점수 산정
- 대응 후보 생성

분석 결과는 Slack을 통해 운영자에게 전달되며, 이후 대응 여부 및 액션 선택에 활용된다.

(2) Plan 단계 (2차 분석)

Analyze 단계에서 생성한 대응 후보의 구체적인 실행 계획을 생성한다.

- 각 액션에 대해 최대 5단계의 실행 절차 생성
- Step Functions에서 실제 실행 가능한 형태로 구조화

2.6. 자동 대응 및 격리

AI 분석 결과에 따라 대응이 필요하다고 판단되면, AWS Systems Manager를 통해 다음과 같은 조치를 수행한다.

- IAM Role 교체 또는 권한 제한
- EC2 인스턴스 격리
- 메모리 덤프 수행
- AMI 생성 및 신규 인스턴스 실행
- 기존 인스턴스 중지

격리된 리소스는 별도의 VPC 환경에서 관리되며 운영 환경과 분리된 상태에서 추가 분석이 가능하다. 특히 메모리 덤프의 경우, 운영체제(Linux/Windows)에 따라 서로 다른 방식으로 수행되며 이후 S3에 저장된다.

또한, 대응 과정에서 오류 발생 여부를 추적하여 다음의 상태로 구분해 기록한다.

- SUCCESS
- PARTIAL_SUCCESS
- FAIL

2.7. 대응 로그 저장 및 모니터링

모든 대응 결과는 S3에 저장되며, 이후 Amazon Managed Grafana를 통해 시각화된다.

또한, 대응 상태 및 주요 이벤트는 Slack을 통해 전달되어 운영자가 실시간으로 상황을 인지하고 개입할 수 있도록 설계하였다.

3. 주요 파이프라인

3.1. 탐지

본 아키텍처는 AWS가 제공하는 보안 솔루션인 GuardDuty, Macie, WAF, Inspector, Security Hub를 기반으로 분석 및 대응을 진행한다.

따라서 이미 탐지된 finding의 파이프라인만을 담당하고 있다.

탐지 단계의 목적은 다음과 같다.

- ❶ 탐지된 finding의 누락 없이 다음 단계로의 전달
- ❷ AI 분석 전, finding의 전처리를 통해 불필요한 AI 분석 제거

탐지 단계는 다음과 같이 이루어진다.

- ❶ AWS Native 보안 서비스에서 발견한 finding이 Security Hub로 집계된다.
- ❷ finding이 Security Hub에 등록되는 즉시 EventBridge가 해당 finding의 정보를 Lambda에게 전송한다.
- ❸ Lambda는 해당 finding이 짧은 시간 내에 중복되어 발생한 것인지, 본 아키텍처에 적용 가능한 종류인지 등의 기준으로 필터링한 후 Step Functions에 전달한다.

AWS의 보안 서비스들이 각자의 역할을 수행하며 finding을 찾으면, 이를 자동으로 Security Hub로 전달하기 때문에 사용자의 선호도에 따라 GuardDuty, Macie 등의 서비스를 포함시키지 않을 수 있으며 Security Hub만 활성화되어 있다면 동작 가능하다.

Security Hub에서 finding들은 언제나 ASFF 속성을 가지므로, 안정적으로 AI 분석 및 이후 단계를 수행할 수 있다.

Service Usages: 보안 서비스(GuardDuty, Macie 등), Security Hub, EventBridge

3.2. 자동 대응

AI 분석 단계의 목적은 다음과 같다.

- ❶ 심각도 및 영향도가 높은 이벤트만 전달해 관리자 피로도 저하
- ❷ 자동 분석 및 대응 방식 추천을 통한 신속한 대응

AI 분석 단계는 다음과 같이 이루어진다.

- ❶ 탐지 단계의 EventBridge가 Step Functions에 해당 finding을 전달한다.
- ❷ Step Functions에서 기본 세팅을 마친 후, Bedrock 전송 Lambda 활성화
- ❸ Lambda는 지정된 AI 모델에게 finding의 정보를 전송하고 이에 따른 응답을 받는다.
- ❹ 응답의 내용에 따라 추후 대응을 결정한다.

AI 분석에는 Claude 3.5 Sonnet 모델을 사용하여 분석을 진행한다.

Analyze 과정에서는 finding을 분석하여 심각도, 추천하는 대응과 대응 시 영향도를 수치화해 응답하고, **Plan 과정**에서는 해당 finding에 적용 가능한 대응의 단계를 나타내어 응답한다. Prompt를 통해 JSON 형식으로만 응답하며, Rule Book 이나 여러 내부 보안 문서를 삽입하여 심각도, 영향도를 측정하는데 도움을 줄 수 있다.

분석 내용은 요약, 위험도, 영향도, finding 개요, 후보 대응 방안을 포함한다. 특히 **요약, 영향도, 후보 대응 방안**은 관리자로 하여금 간편하면서 신속한 대응을 가능하게 한다. 후보 대응 방안을 여러 개 선택 가능하며, 선택한 후보 대응 방안은 미리 지정된 SSM 로직에 따라 처리된다.

Slack에게 메시지를 전송하기 전, Analyze 과정과 Plan 과정을 거치며 finding에 대한 최종 정보를 받아오고, 이 모든 정보를 한번에 Slack에 전송한다.

관리자는 대응 과정에서 **Slack 채널**을 통해 쉽게 대응 방향을 조정할 수 있다.

특정 Slack 채널과 Slack 봇을 등록한 뒤, AI 분석의 Analyze 모드의 결과값을 채널에 전송한다.

관리자는 메시지를 확인하고 후보 대응 방안을 선택하거나, 대응을 거부할 수 있다. 후보 대응 방안을 선택하면 그 결과값에 따른 단계별 계획을 다시 Slack 채널을 통해 안내하고, 자동 대응을 시작한다.

전반적인 Slack 기능의 구조는 다음과 같다.

- ① Step Functions에서 Sender Lambda 함수를 실행한다.
- ② Sender 함수는 waitForTaskToken 기능을 이용해 Step Functions을 잠시 중단하고 Slack 채널에 메시지를 전송한다. 관리자의 답변은 미리 Slack 봇에 지정해둔 Lambda Function URL로 자동 전송되며, 해당 URL에는 Receiver Lambda 함수가 대기한다.
- ③ 정해진 시간(예: 5분)내에 관리자의 답변이 돌아오지 않을 시, 리마인드 메시지를 전송하며 1시간의 기간을 두고 계속 전송 가능하다.
- ④ 관리자의 답변이 돌아올 시, Receiver 함수가 Step Functions을 재개하며 처리 선택 메시지를 Slack에 전송한다.

리마인드: 보안 위협 분석 보고서

Inspector 에서 새로운 위협이 탐지되었습니다.
상태: 승인 대기 중

Summary: EC2 인스턴스에서 의심스러운 아웃바운드 트래픽 탐지

Risk_level: HIGH

 영향도 점수
75 / 10

Severity HIGH	Instance ID <code>i-003471b7faf5acc5e</code>
Finding Type Software and Configuration Checks/Vulnerabilities/CVE	Execution Source securityhub-eventbridge
Finding ID arn:aws:inspector2:ap-northeast-2:073109174888:finding/75528fe1d92c033e181c50f755c9c795	Resource ARN <code>arn:aws:ec2:ap-northeast-2:073109174888:instance/i-003471b7faf5acc5e</code>

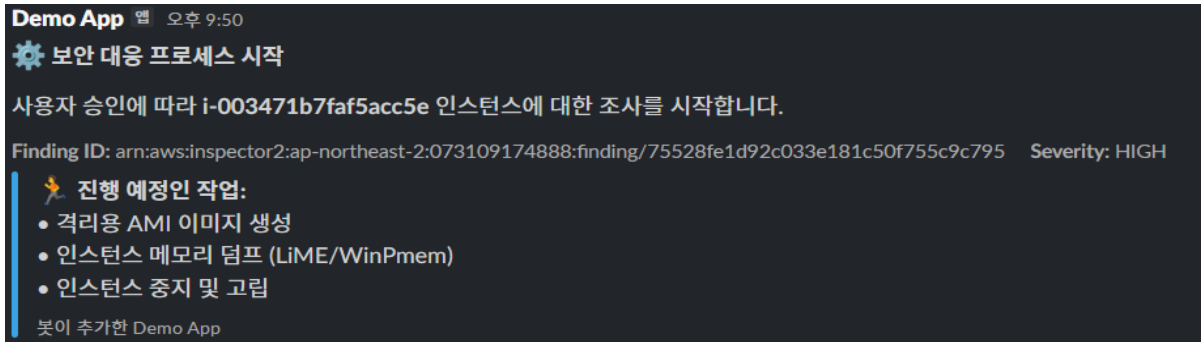
 대응 방안 선택 (다중 선택 가능)

- ☐ ISOLATE_INSTANCE
추가 피해 방지를 위해 인스턴스 격리
- ☐ SNAPSHOT_INSTANCE
포렌식 분석을 위한 인스턴스 스냅샷 생성
- ☐ REVOKE_IAM_ROLE
잠재적으로 손상된 IAM 역할 권한 해제
- ☐ MONITOR
유사한 활동 탐지를 위해 다른 인스턴스 모니터링 강화

 선택 항목 실행  반려

봇이 추가한 Demo App

▲ Slack 채널에 전송된 finding 정보(Analyze + Plan 모드)



▲ 대응 방안 선택 후, 확인 응답이 전송된 Slack 채널

위 Slack 기능을 안전하게 구현하기 위해 다음과 같은 세부 기술이 사용되었다.

- ❶ Lambda Function URL
- ❷ Slack SDK Signing Secret

Receiver 함수는 Lambda Function URL 기능을 이용해 자체 URL 엔드포인트를 제작한 후, 해당 엔드포인트에 접속할 시 함수가 실행되도록 설정되어 있다.

이 때 누구나 Lambda Function URL에 접속 가능하고 Slack 봇은 AWS의 IAM에 등록할 수도 없기 때문에 Slack SDK Signing Secret 기능을 이용해 보안성을 증대시켰다.

미리 등록된 Secret 키를 가지고 있지 않다면, Receiver 함수는 해당 요청을 거부한다. 따라서 Slack 기능에 안전성을 부여하고 있다.

본 시스템은 AWS가 제공하는 Step Functions과 Systems Manager를 사용하여 자동 대응 및 격리를 진행한다.

Step Functions 기반의 자동 대응 Workflow 목적은 다음과 같다.

- ❶ 신속한 증거 보존 및 격리
- ❷ 유연하고 안전한 파이프라인 운영

Step Functions를 통한 자동 대응 단계는 다음과 같이 진행된다.

- ❶ 탐지 단계에서 전달받은 finding 데이터를 기반으로 심각도를 확인한다. 심각도가 'HIGH' 이상일 경우, Bedrock 및 Slack 승인 프로세스를 호출한다.

- ② 관리자가 Slack을 통해 대응을 승인하면, 침해된 EC2 인스턴스에 격리 및 포렌식을 위한 임시 IAM 프로필을 부여한다.
- ③ 관리자가 선택한 대응 조치에 따라 다음의 보안 작업들을 조건부로 수행한다.
- ④ 대응 과정에서 발생한 모든 로그, 소요 시간, 수행 상태(Success/Partial Success/Fail)를 종합하여 S3 버킷에 JSON 형태로 기록한다.

대응 시나리오	주요 내용
ISOLATE_INSTANCE	AMI 생성 및 격리 네트워크로 재배포
SNAPSHOT_INSTANCE	메모리 덤프수행 및 S3 저장
REVOKE_IAM_ROLE	기존 IAM 권한 회수
BLOCK_IP	인스턴스의 보안 그룹 변경

작업 수행 중 예상치 못한 문제로 특정 스텝이 실패하더라도 Step Functions의 Catch 기능을 활용해 Workflow 전체가 중단되지 않도록 했다. 실패한 내역은 ErrorLog에 누적 기록되며, 최종적으로 Partial Success 상태로 전환되어 관리자에게 보고된다.

3.3. 모니터링

본 시스템은 Amazon S3에 저장된 로그 데이터를 기반으로 실시간 보안 모니터링 대시보드를 구성한다. 로그 데이터는 수집 후 가공 과정을 거쳐 시각화되며, 대시보드 구성 파이프라인은 다음과 같다.

S3 → Lambda → Loki → Grafana

S3에 저장된 로그는 Lambda를 통해 수집된 후 JSON 형태로 변환되어 Loki로 전달되며, 이후 Grafana에서 다양한 패널 형태로 시각화된다. 이 과정에서 로그는 이벤트 유형, 위험도, 대응 결과 등의 정보로 구조화된다.

본 시스템은 단순 로그 조회가 아닌, “탐지 -> 조치 -> 결과”의 전체 보안 흐름을 추적하는 데 목적이 있다. 이를 위해 대시보드는 전체 구조도 또는 특정 범위의 구조를 시각적으로 표현하고, 관리자 조치 발생 시 조치 전(Before)과 조치 후(After)의 상태를 비교하여 시스템 변화 여부를 직관적으로 확인할 수 있도록 구성하였다.

또한, 보안 이벤트의 흐름을 명확히 파악할 수 있도록 탐지 → 조치 → 결과 각 단계에 시간 정보를 함께 제공하여 처리 과정을 단계별로 추적할 수 있도록 하였다. 나아가, 누적된 보안 위협과 대응 결과를 그래프 형태로 시각화함으로써 전체 보안 현황과 대응 이력을 한눈에 파악할 수 있도록 설계하였다.

[대시보드 구성]



① 패널 1: 핵심 숫자 요약

- 총 보안 이벤트
- HIGH 위험 이벤트
- 자동 대응 실행 수
- SSM 성공 실행 수
- 구조 비교 수행 횟수
- 위협 유형 분포
- 탐지 제품 분포

패널 1은 보안 이벤트의 규모와 위험도를 한눈에 파악하기 위한 목적을 가진다.

탐지 -> 조치 -> 결과 타임라인

탐지 → 조치 → 결과 타임라인

시간	단계	탐지 유형	조치	결과	ami_id	dump_path	duration	error_log	os_type	sf_status
2026-04-24 15:47:34.314	결과									
2026-04-24 15:47:32.837	조치		MONITOR	SUCCESS						
2026-04-24 15:47:32.837	결과									
2026-04-24 15:47:32.837	결과									
2026-04-24 15:47:32.837	결과									
2026-04-24 15:47:32.837	결과									
2026-04-24 15:47:31.417	조치		ISOLATE_INSTANCE	FAILED						
2026-04-24 15:47:31.417	결과									
2026-04-24 15:47:31.417	결과									

② 패널 2: 탐지 -> 조치 -> 결과 타임라인

- 탐지 -> 조치 -> 결과 타임라인

패널 2는 보안 이벤트의 “탐지 → 조치 → 결과” 흐름을 파악하기 위한 목적을 가진다.

Before / Action / After 구조 흐름

Before 구조 (조치 전 상태) ⓘ

스냅샷 시간	인스턴스 수	SSM 관리 수	
2026-04-24T08:47:50.959644+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:34.556110+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:33.056820+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:31.617572+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:30.211665+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:28.737624+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:27.296129+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "

관리자 조치 / 자동 대응 ⓘ

시작 시간	완료 시간	조치 유형	결과	대상 인스턴스	조치 내용	ami_id	dun
2026-04-18T04:01:00Z	2026-04-18T04:01:18Z	ISOLATE_INSTANCE	SUCCESS	i-0e5555555555555555	SSH brute-force source instance isolated.		
2026-04-18T03:30:00Z	2026-04-18T03:30:05Z	MONITOR	SUCCESS	i-0c3333333333333333	Enhanced monitoring enabled for policy-related event.		
2026-04-18T03:00:00Z	2026-04-18T03:00:15Z	ISOLATE_INSTANCE	FAILED	i-0d4444444444444444	Isolation failed due to missing IAM permission.		
2026-04-18T02:10:00Z	2026-04-18T02:10:20Z	DATE_SECURITY_GRC	SUCCESS	i-0b2222222222222222	Inbound 0.0.0.0/0 rule removed from probed instance.		
2026-04-18T01:12:05Z	2026-04-18T01:12:40Z	INAPSHOT_INSTANCE	SUCCESS	i-0a1111111111111111	Snapshot created for forensic investigation.		
2026-04-	2026-04-	ISOLATE_INSTANCE	SUCCESS	i-0a1111111111111111			

After 구조 (조치 후 상태) ⓘ

스냅샷 시간	인스턴스 수	SSM 관리 수	
2026-04-24T08:47:52.195932+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:35.778338+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:34.314819+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:32.837575+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:31.417656+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:29.994386+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "
2026-04-24T08:47:28.533103+00:00	6	2	-Ob4ab3d804dde450f", "SubnetId": "

③ 패널 3: Before / Action / After 구조 흐름

- Before 구조 (조치 전 상태)
- 관리자 조치 / 자동 대응
- After 구조 (조치 후 상태)

패널 3는 보안 이벤트가 어떤 과정을 거쳐 처리되었는지 추적하는 목적을 가진다.

구조 변화 결과 (Diff Result)					
테스트 결과 요약					
테스트 결과 정상					
Diff 결과					
비교 시작	변경 여부	변경 결과	조치 전 인스턴스 수	조치 후 인스턴스 수	
2026-04-25T16:16:29.486752+00:00	없음	"removed_instances": [], "changed_instance_state": []	5	5	
2026-04-25T16:13:25.240955+00:00	없음	"removed_instances": [], "changed_instance_state": []	5	5	
2026-04-25T16:12:13.618277+00:00	없음	"removed_instances": [], "changed_instance_state": []	5	5	
2026-04-25T16:05:55.699015+00:00	없음	"removed_instances": [], "changed_instance_state": []	5	5	
2026-04-25T16:53:16.59018+00:00	없음	"removed_instances": [], "changed_instance_state": []	5	5	
2026-04-25T15:51:16.176355+00:00	없음	"removed_instances": [], "changed_instance_state": []	5	5	
2026-04-25T16:52:09.345358+00:00	없음	"removed_instances": [], "changed_instance_state": []	5	5	
2026-04-25T19:43:05.609186Z+00:00	없음	"removed_instances": [], "changed_instance_state": []	5	5	

구분	주요 내용
기능 정의	[모니터링 기능의 상세 내용]
핵심 숫자 요약	이벤트 수, 위험도, 대응 결과 등 주요 지표를 수치로 요약 제공
탐지 → 조치 → 결과 타임라인	보안 이벤트를 시간 흐름에 따라 단계별로 확인 가능
Before / Action / After 구조 흐름	조치 전·후 상태를 비교하여 변화 흐름을 직관적으로 파악
구조 변화 결과 (Diff Result)	조치로 인한 시스템 변화 여부 및 차이 정보 제공
대시보드 구성	[모니터링 대시보드 구성 요소]
패널 1	총 보안 이벤트, HIGH 위험 이벤트, 자동 대응 실행 수, SSM 성공 실행 수, 구조 비교 수행 횟수, 위험 유형 분포, 탐지 제품 분포
패널 2	탐지 -> 조치 -> 결과 타임라인

구분	주요 내용
패널 3	Before 구조 (조치 전 상태), 관리자 조치 / 자동 대응, After 구조 (조치 후 상태)
패널 4	대응 결과 요약, Diff 결과

④ 패널 4: 구조 변화 결과 (Diff Result)

- 대응 결과 요약
- Diff 결과

패널 4은 조치 전후의 시스템 상태를 비교하여 실제 변화가 발생했는지를 보여주는 목적을 가진다.

대시보드를 통해 자동 대응 결과와 구조 변화 정보를 시각적으로 제공함으로써, 보안 이벤트 처리 결과를 빠르게 이해하고 시스템 상태 변화를 직관적으로 파악할 수 있다.

4. 시뮬레이션 결과

4.1. 자동 대응 결과

아래 GuardDuty tester를 통해 시뮬레이션을 진행하였다.

<https://github.com/aws-labs/amazon-guardduty-tester>

4.2. 기존 방식 vs AI 도입 비교

기존 방식: Security Hub로 집계된 finding을 관리자가 직접 확인하여 일일이 분류 및 대응

항목	기존 방식	프로젝트 구현 방식	개선율
실질 finding	35	15	233%
finding 당 처리 시간	15분	< 10분	> 150%

*실질 finding: 관리자가 처리해야 하는 finding

기존 방식에서는 Security Hub에 집계된 finding이 35개이고, 모든 finding에 대해 관리자가 일일이 이를 확인하고 대응 방법을 생각해 대응을 시도해야 했다. 이미 대응 매뉴얼이 설립되어 있다는 가정 하에, 수동적인 대응은 당연히 10분 이상의 대응이 걸릴 수 밖에 없다.

본 프로젝트의 솔루션을 도입할 시, 관리자가 처리해야 하는 실질 finding의 수가 15개로 줄어든 것을 알 수 있다. 관리자는 AI가 한 번 정리해준 정보를 바탕으로 Slack 화면에서 대응 여부를 결정할 수 있었고, 대응을 고민하고 자동 대응에 실패한 소수의 사례만 갈무리하면 되기에 처리 시간이 반절 이상 줄어들 수 있었다.

5. 결론

본 프로젝트에서는 클라우드 환경에서 발생하는 다양한 보안 이벤트를 대상으로 탐지부터 분석, 대응, 모니터링까지의 전 과정을 자동화한 End-to-End 보안 대응 시스템을 설계하고 구현하였다. 또한, GuardDuty Tester를 기반으로 총 32개의 공격 시나리오를 재현하고, 약 10분동안 총 702건의 보안 이벤트를 탐지하여 시스템의 End-to-End 자동 대응 성능을 검증하였다. 이 중 57건(약 8.1%)의 HIGH 위험 이벤트가 식별되었으며, 모든 이벤트는 Security Hub -> EventBridge -> Lambda -> Step Functions 의 파이프라인을 통해 100% 정상 전달 및 처리되었다.

AI 기반 필터링을 활용함으로써 관리자가 실제로 대응해야 하는 이벤트 수를 35건 => 15건으로 약 57% 감소시켰으며, 이벤트당 처리 시간 역시 15분 => 10분 미만으로 단축(최소 33% 이상 개선)되었다.

특히 EC2 리소스가 포함된 이벤트에 대해서는 SSM 기반 자동 격리 및 포렌식 대응이 수행되었으며, 모든 대응 과정은 Slack 알림 및 Grafana 대시보드를 통해 실시간으로 추적 가능함을 확인하였다.

결과적으로 본 시스템은 탐지 -> 분석 -> 대응 -> 모니터링까지 전 과정을 자동화하면서도, AI 기반 의사결정을 통해 불필요한 대응을 줄이고 대응 속도를 향상시킨 실효성 있는 자율 보안 대응(Self-Healing) 구조를 검증하였다.

6. 참고문헌

[1] 김민정 외 2인, “소프트웨어 공급망 공격에서의 클라우드 악용 사례 및 완화 방안 분석”, Review of KIISC, vol. 35, no.1, pp 50-53, 2025

[2] CIS Controls, “CIS Critical Security Controls”, Version 8.1, 2025.03